Mailvora

BUSINESS EMAIL

System Infrastructure

Architecture, system flows and security flows of the Mailvora business email platform: components, network, data paths, trust boundaries and controls.

Version	Date	Status	Classification
1.0	15 October 2026	Pre-production baseline	Confidential · operators

© 2026 Mailvora. All rights reserved.

Powered by TECHCORE SOLUTIONS

Contents

1	Executive summary	Purpose, scope and key properties
2	System context	Users, external services and the platform boundary
3	Deployment architecture	Hosts, containers, networks, ports and volumes
4	Component inventory	What each part does and where it runs
5	System flows	Outbound mail, inbound mail and mailbox access, payments, verification
6	Security architecture	Request security pipeline, trust boundaries, defence in depth
7	Security controls	Controls matrix, secrets, threats and mitigations
8	Data protection	Data inventory, retention, backups, Kenya Data Protection Act
9	Operations	Monitoring, backup and restore, incidents, release gates
A	Appendix: network and port reference	Every listening port and who may reach it
B	Document control	Ownership, review cycle and sources

How to read the diagrams. Every figure is drawn as vector graphics: zoom in as far as you need without loss of quality. Green elements are Mailvora's own components, blue is the mail tier, indigo is data at rest, amber is the network edge, grey is outside parties, and red dashed lines mark trust boundaries.

1 Executive summary

Mailvora is a self-hosted, multi-tenant business email platform for Kenyan institutions and developers. It relays transactional email for applications through a REST API, hosts work mailboxes on an organisation's own domain, and bills flat monthly prices in Kenyan shillings through M-Pesa.

1 VPS
Docker Compose deployment, no git required

8
services: Nginx, web app, API, PostgreSQL, Postfix, Dovecot, Rspamd, Redis

7
public ports: 22, 25, 80, 443, 465, 587, 993

KES
flat pricing; M-Pesa STK push via PesaTide

Purpose and scope

This document describes how the platform is built and how data and trust move through it. It is the reference for operators deploying and running Mailvora, for security reviewers and penetration testers, and for engineers changing the system. It covers the production topology defined in `backend/docker-compose.yml` and the host Nginx site in `backend/infra/nginx/mailvora.conf`.

Architecture principles

- **Proven mail software for protocols.** Postfix handles SMTP, Dovecot handles IMAP, LMTP, SASL, Sieve and quotas, and Rspamd filters spam. Mailvora's Rust service is the control plane and never implements SMTP or IMAP itself.
- **Backend-for-frontend.** Browsers talk only to the PHP web application; it calls the Rust API over a private address and keeps API session cookies server-side.
- **Tenant isolation by construction.** The organisation is always derived from the authenticated session or API key, never from request input, and every query is scoped by it.
- **Secure by default.** Production refuses to start with unsafe settings (plain-HTTP addresses, insecure cookies, debug output, development shortcuts).
- **Durable, idempotent processing.** Messages and jobs are stored before they are acknowledged; workers claim jobs with leases, retry with back-off and never send twice for the same idempotency key.

Key properties

Property	How it is achieved
Confidentiality	TLS 1.2+ on every public endpoint; Argon2id password hashes; DKIM keys and webhook secrets encrypted with AES-256-GCM; sealed, session-bound links for every signed-in page; encrypted backups.
Integrity	DKIM signatures on all outbound mail; HMAC-signed webhooks in both directions (Mailvora → customers, PesaTide → Mailvora); CSRF tokens on every form; audit log of privileged actions.
Availability	Containers restart automatically; queue leases recover from worker crashes; per-IP and per-account rate limits; nightly encrypted off-site backups with a practised restore.
Accountability	Every sign-in, MFA, role, key, billing and suspension event is written to the audit log with actor, target and IP; operators review it on the Security page.

2 System context

Three kinds of people and systems use Mailvora, and the platform depends on five kinds of outside service. Everything inside the green box runs on the operator's own server.

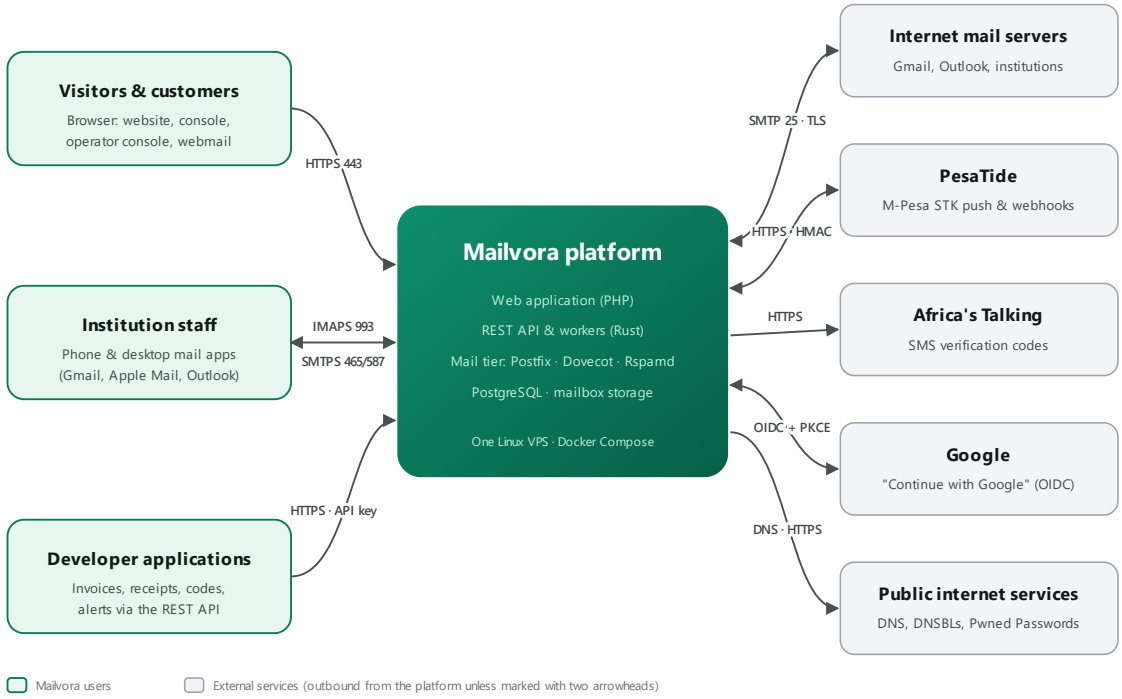


Figure 1. System context. Customers, staff and applications reach the platform on the left; the platform reaches external services on the right. PesaTide also calls back with signed payment webhooks, and other mail servers deliver inbound mail on port 25.

Users and roles

Who	What they do	How they authenticate
Individual developer	Sends transactional email from an application; manages domains, keys, templates, webhooks, billing.	Username or email or phone + password; optional TOTP; Google sign-in
Institution owner / admin	Everything above, plus hosted mailboxes, aliases, support contacts, team roles.	As above; MFA strongly recommended (flagged on the operator Security page)
ICT support member	Helps staff: resend invitations, activation links, reset links, unlock accounts. Never sees or sets passwords.	Console account with the `ICT support` role
Mailbox user (staff, students)	Reads and sends work mail in webmail or a phone app; follows the guided phone setup.	Mailbox address + password (Argon2id), over TLS only
Platform operator	Runs the platform: tenants, plans, invoices, queue, mail-app settings, security overview, documentation.	Console account with operator rights; **MFA required in production**
Application (machine)	Calls the REST API.	Scoped API key `mv_live_…` / `mv_test_…`, optionally restricted by IP and sender domain

3 Deployment architecture

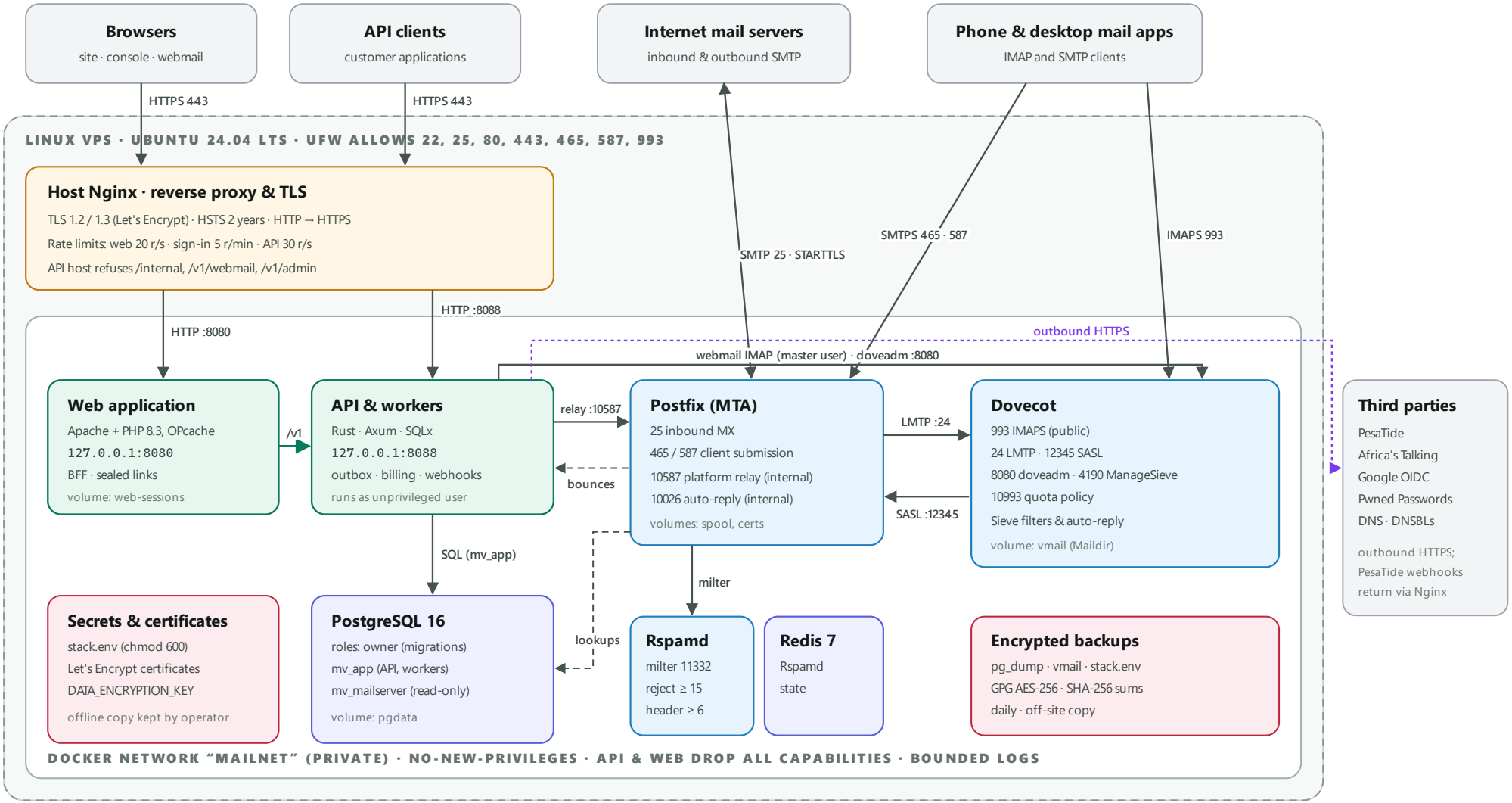


Figure 2. Deployment architecture. Only Nginx (80/443) and the mail ports (25, 465, 587, 993) face the internet. The web application and API listen on loopback and are reached through Nginx. Every other port exists only on the private Docker network.

4 Component inventory

Component	Technology	Responsibility	Listens on
Host Nginx	Nginx, Let's Encrypt	TLS, HSTS, HTTPS redirect, per-IP rate limits; routes the app, API and autoconfig hosts; blocks internal API paths.	80, 443 (public)
Web application	PHP 8.3, Apache, OPcache	Website, consoles, webmail, phone setup, docs; CSRF, sessions, sealed links, strict CSP; backend-for-frontend to the API.	127.0.0.1:8080
API & workers	Rust (Axum, SQLx, Tokio)	REST API (`/v1`): auth, tenancy, billing, payments, domains, templates; delivery, webhook and maintenance workers.	127.0.0.1:8088
PostgreSQL	PostgreSQL 16	System of record (tenants, users, mailboxes, messages, jobs, invoices, audit log); separate roles for migrations, runtime and mail servers.	5432 (private)
Postfix	Postfix	Inbound MX with recipient validation, authenticated submission, platform relay for API mail, auto-reply listener.	25, 465, 587 (public); 10587, 10026 (private)
Rspamd	Rspamd + Redis	Spam scoring milter (reject at 15, header at 6, no greylisting).	11332 (private)
Dovecot	Dovecot, Pigeonhole	IMAP, LMTP delivery to Maildir, SASL for Postfix, Sieve and vacation replies, quotas, doveadm for instant revocation.	993 (public); 24, 12345, 8080, 4190, 10993 (private)
Backups	`backup.sh`, GnuPG	Daily database, mailbox and config archive, AES-256 encrypted with checksums; pruned; copied off-site.	n/a (cron)

External services

Service	Used for	Trust and failure behaviour
PesaTide	M-Pesa STK push for invoice payment; payment status; webhooks.	Key + secret; HMAC-verified webhooks; polling reconciles. Outage: invoices stay open; operators can record bank payments.
Africa's Talking	Six-digit SMS verification codes.	Codes hashed at rest. Outage or no credentials: email confirmation instead.
Google	"Continue with Google" (OpenID Connect).	Code + PKCE, exchanged server-side; ID token validated. Outage: passwords still work.
Pwned Passwords	Refusing breached passwords.	k-anonymity (5-character prefix), padded; fails open.
Public DNS, DNSBLs	Domain verification, deliverability tools, blocklist checks.	Validating resolver; rate-limited; private addresses refused.

5 System flows

5.1 Outbound mail: an application sends a message

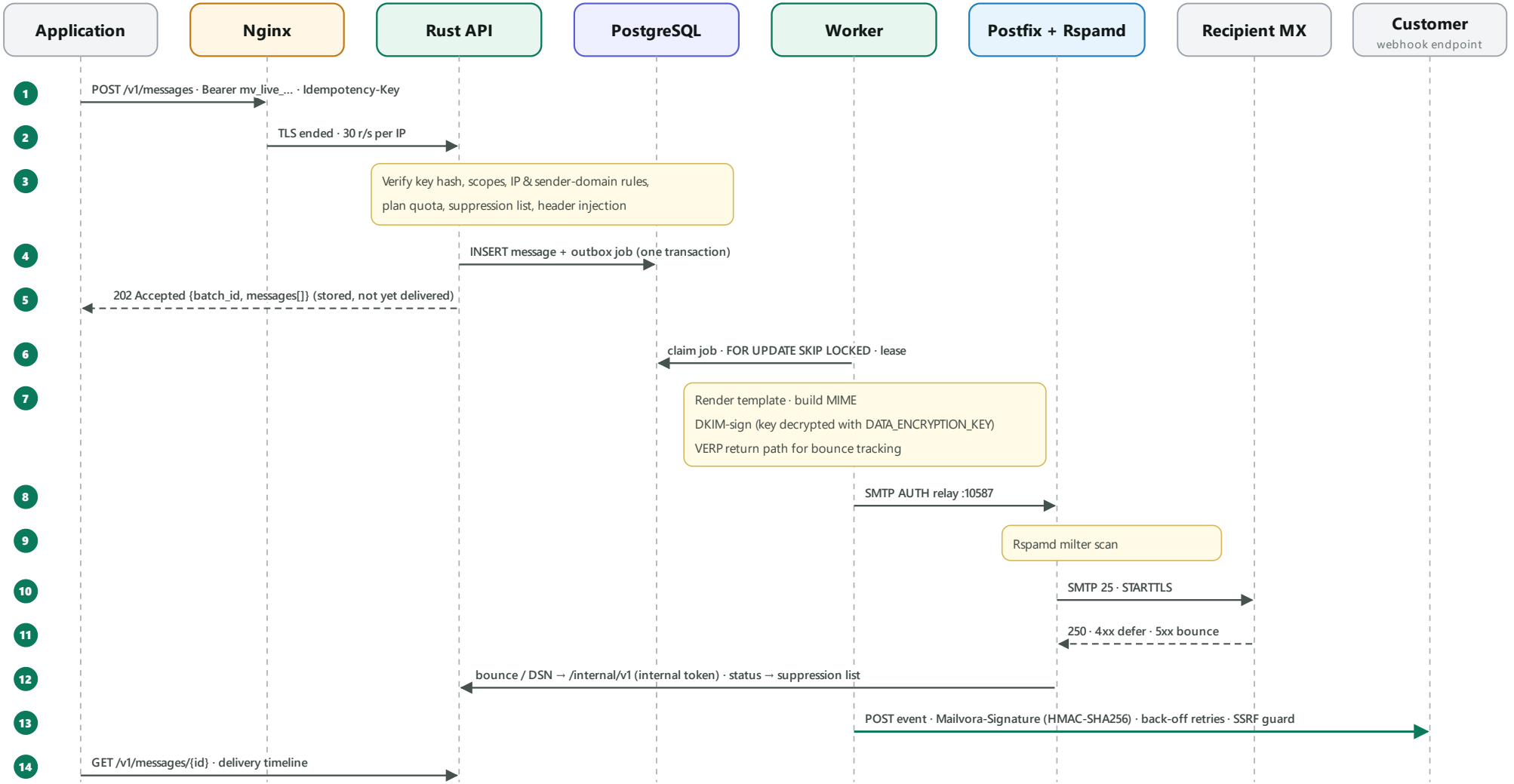


Figure 3. Outbound mail sequence. The API acknowledges only after the message and its job are committed (step 4). Delivery is asynchronous, idempotent and crash-safe; bounces feed suppressions so later sends to dead addresses are refused.

5.2 Inbound mail and mailbox access

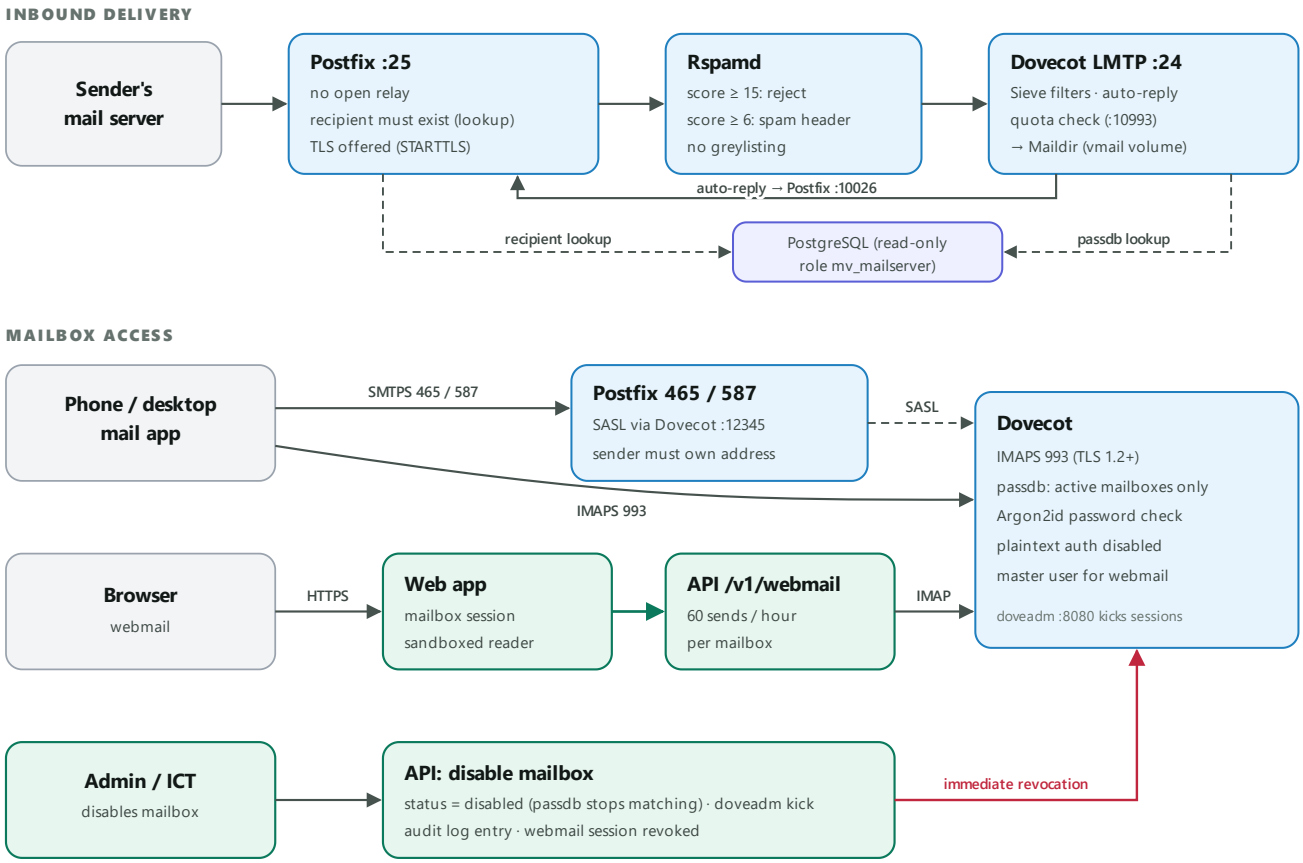


Figure 4. Inbound delivery and mailbox access. Postfix rejects mail for unknown recipients during the SMTP dialogue (no backscatter). Phones, webmail and Postfix submission all authenticate against the same Dovecot password database, so disabling a mailbox ends every access path at once.

Web request flow (browser → web application → API)

1. The browser connects to `app.example.com` over TLS; Nginx applies rate limits and forwards to the web application on loopback.
2. The web application starts the session, opens any sealed `/app?ref=…` link with the session's key, and routes the real path.
3. CSRF, authentication and permission middleware run; the controller calls the API at its private address, presenting the API session cookie kept in the PHP session (never in the browser).
4. The response is rendered; every private address in it is sealed before it is sent, and secrets are shown once.

5.3 Invoice payment with M-Pesa (PesaTide)

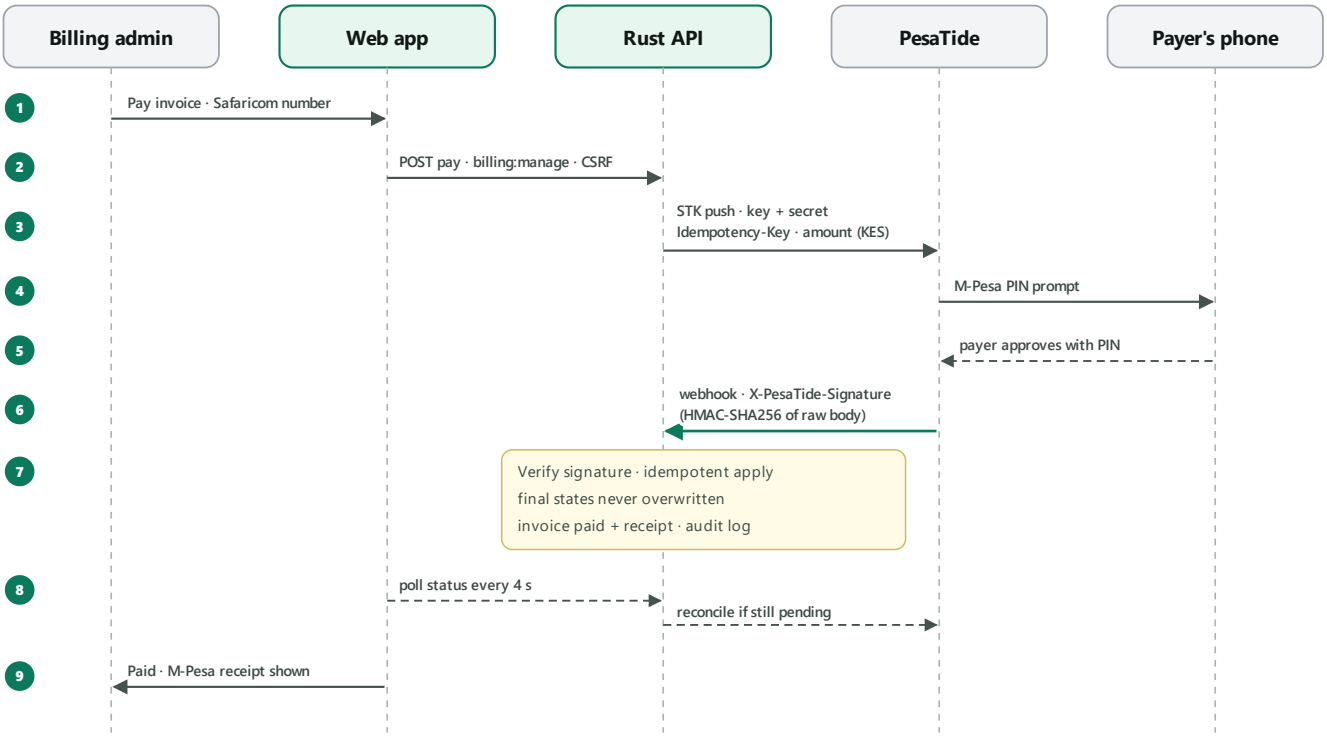


Figure 5. Invoice payment. The webhook is the primary confirmation; polling reconciles a missed webhook. A request expires after 10 minutes and only one may be in progress per invoice.

5.4 Account sign-up and verification

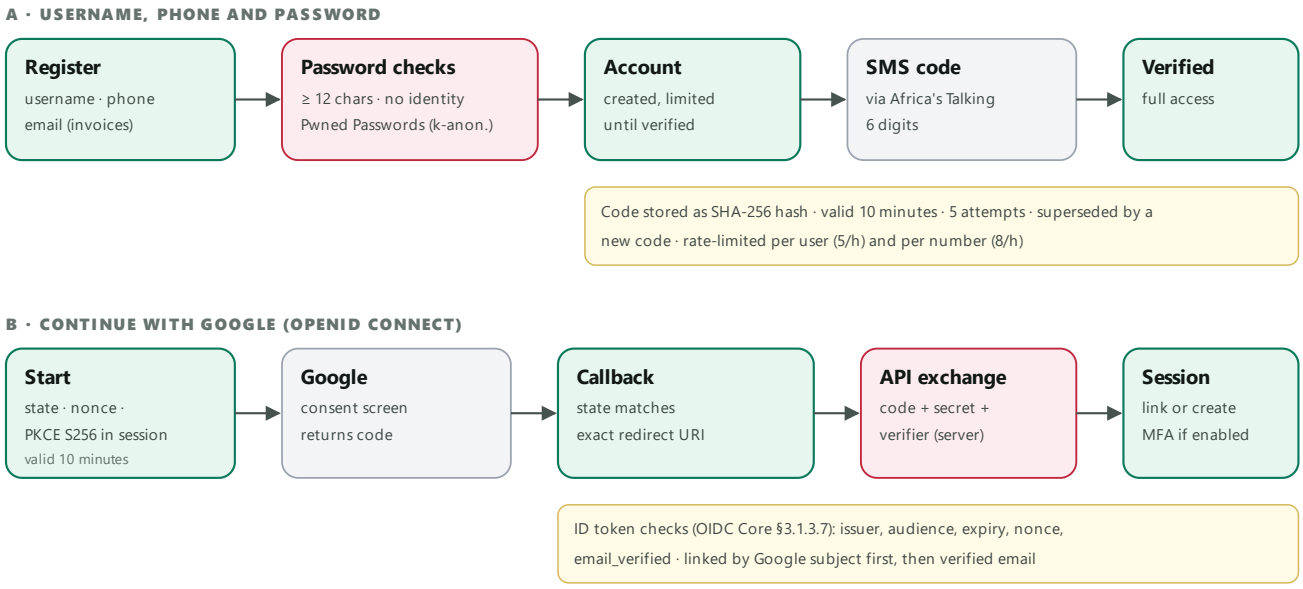


Figure 6. Sign-up and verification. No mail provider is forced on users: phone verification is the default, Google is optional, and email is kept only as a contact for invoices.

6 Security architecture

6.1 Security flow of a browser request

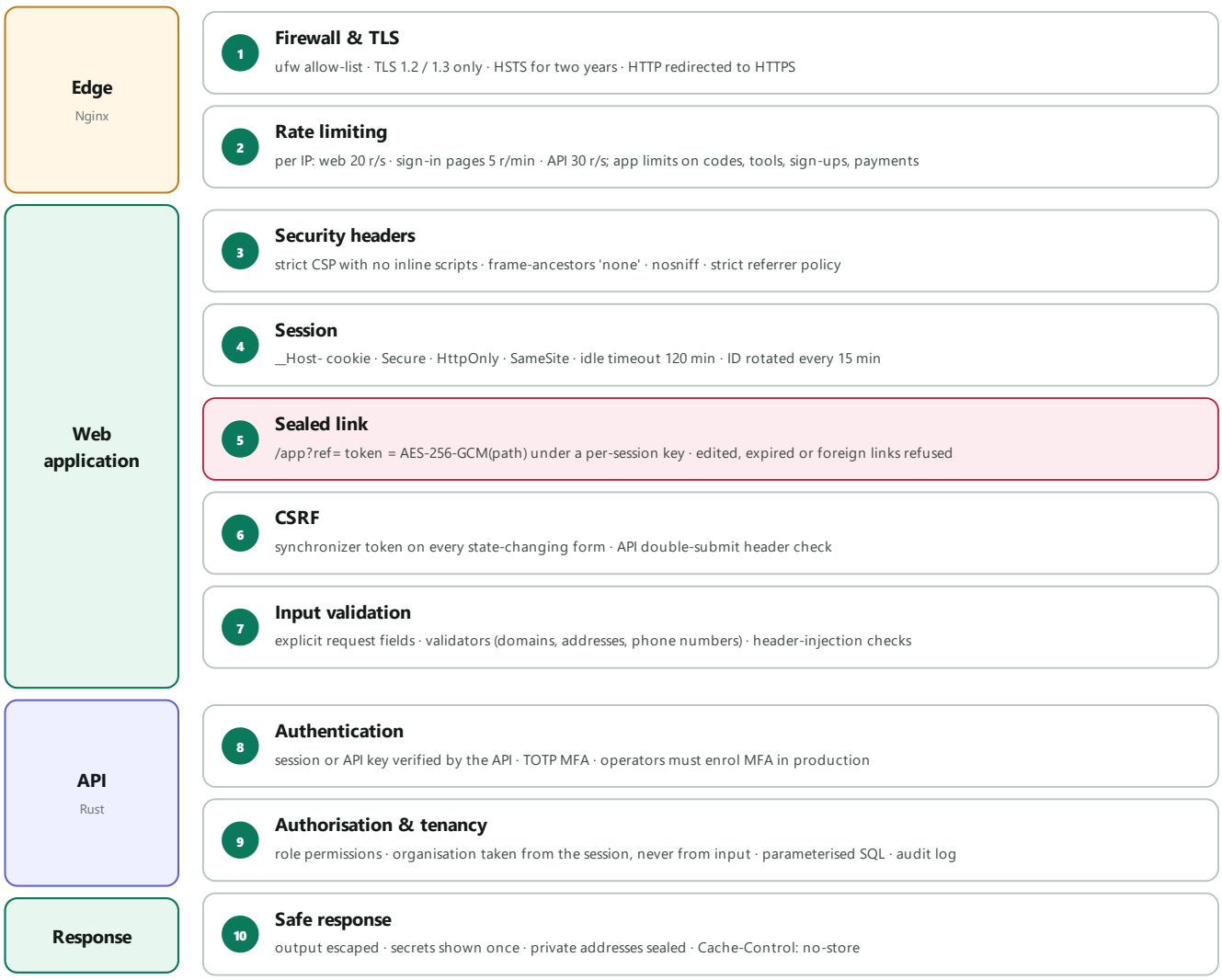


Figure 7. Request security pipeline. A request must pass every layer in order; failure at any step stops it with a safe, generic response. Layer 5 (sealed links) is defence in depth: layer 9 is the control that actually prevents cross-tenant access.

What a refused request receives

Layer	Response
Rate limit exceeded	`429 Too many requests` with a plain message; nothing about the account is revealed.
Sealed link edited or expired	Redirect to the area's home with "That link has expired or was changed"; a typed record address is refused the same way; a direct form post gets `404`.
CSRF token missing or wrong	`419 Page expired`; the form can be submitted again from a fresh page.
Not signed in	Redirect to sign-in with a sealed return address; API: `401` with a stable error code.
Role lacks permission	`403` explaining which role is needed; the operator console answers `404` so it does not reveal itself.
Record in another tenant	`404 Not found`, identical to a record that does not exist.

6.2 Trust boundaries

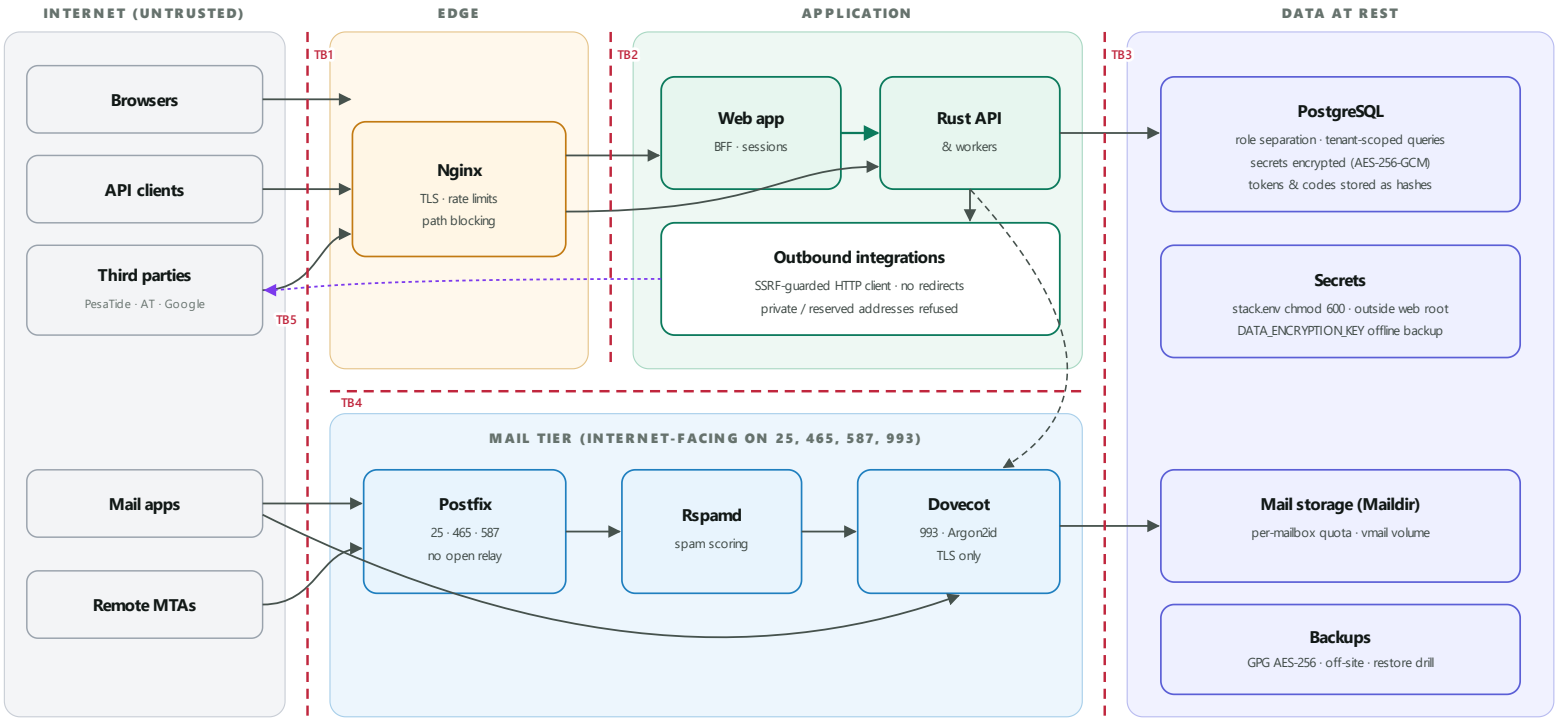


Figure 8. Trust boundaries. Red dashed lines are the points where data crosses from a less-trusted to a more-trusted zone; every crossing has the controls listed below.

ID	Boundary	Controls at the crossing
TB1	Internet → edge and mail tier	Firewall allow-list; TLS 1.2+ everywhere; HSTS; per-IP rate limits; Postfix recipient validation and relay restrictions; Rspamd scoring; Dovecot TLS-only authentication.
TB2	Edge → application	Loopback-only listeners; internal API paths blocked at Nginx; CSP, CSRF, sessions, sealed links, input validation; API keys and sessions verified on every call.
TB3	Application → data	Separate database roles (migrations, runtime, read-only mail servers); parameterised SQL; tenant scoping; secrets encrypted with AES-256-GCM; tokens and codes hashed; backups encrypted.
TB4	Mail tier ↔ application	Platform relay only for the authenticated relay identity; auto-reply listener only from the private network; bounce ingestion requires the internal API token; mail servers read the database through a read-only role.
TB5	Application ↔ third parties	Outbound: SSRF-guarded client (public addresses only, no redirects, DNS-rebinding safe). Inbound: PesaTide webhooks verified by HMAC-SHA256; Google ID tokens validated; credentials only in `stack.env`.

6.3 Defence in depth

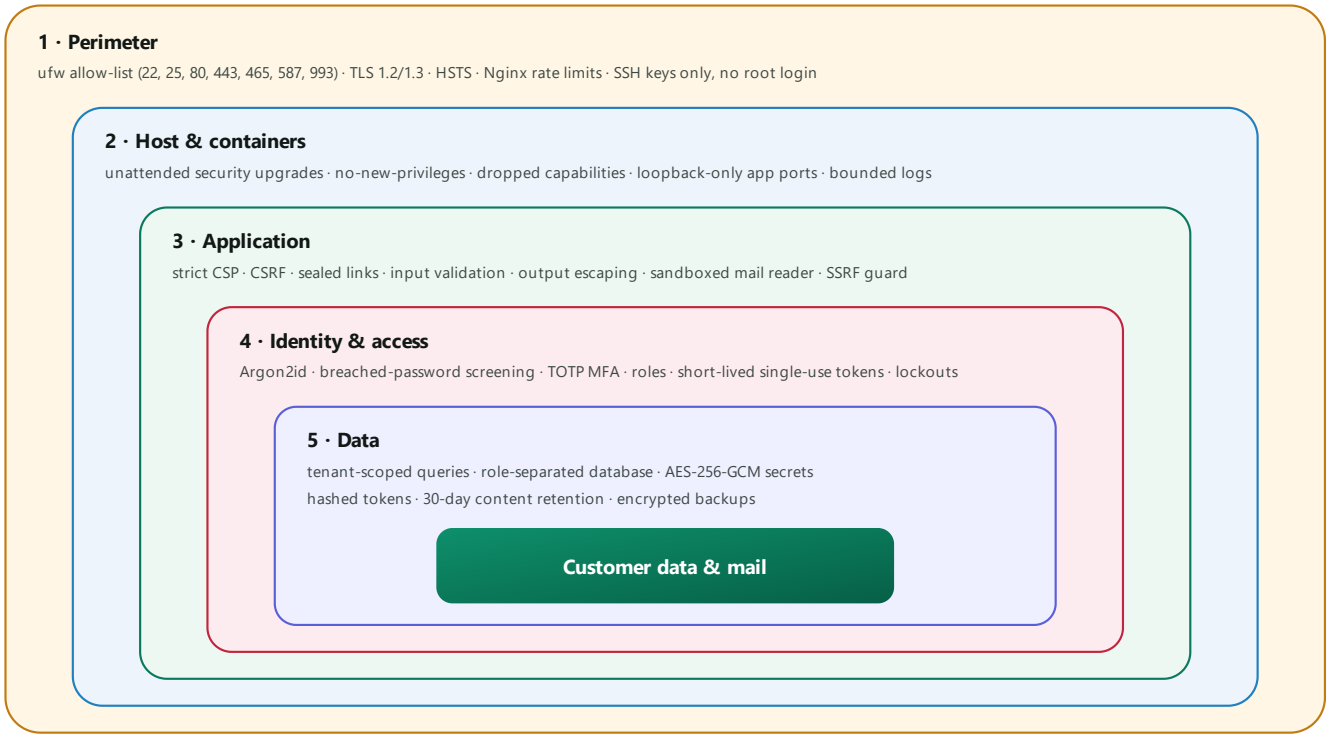


Figure 9. Defence in depth. An attacker must defeat several independent layers to reach customer data; no single control is relied upon.

6.4 Tenant isolation

Every organisation-owned row carries its organisation identifier, enforced by composite foreign keys. The API derives the organisation from the authenticated session or API key and adds it to every query; request bodies and URLs never choose the tenant. Mailbox users are confined to their own mailbox, and the webmail session cannot call console endpoints. Integration tests attempt cross-tenant access for every resource type and must receive "not found".

7 Security controls

7.1 Controls matrix

Domain	Control	Reference
Passwords	Argon2id (m = 19 MiB, t = 2, p = 1) for console and mailbox passwords; minimum 12 characters; no identity substrings; common and breached passwords refused.	NIST SP 800-63B; ASVS V6
MFA	TOTP for console accounts; platform operators refused in production until enrolled; owners without MFA flagged to operators.	ASVS V6; CISA
Tokens	Reset 1 h, activation 7 days, phone codes 10 min; stored as SHA-256 hashes; single use; superseded by newer tokens; purged daily.	ASVS V7
Sessions	Server-side sessions; `__Host-` Secure HttpOnly SameSite cookie; idle expiry; ID rotation; password change or reset revokes other sessions and IMAP connections.	ASVS V7
Authorisation	Deny by default; role permissions; organisation from the session; last owner protected; no self-promotion; operator console hidden from others.	OWASP API1/API5
Web	Strict CSP without inline script; CSRF tokens; output escaping; sealed links; secrets displayed once; received mail rendered in a sandboxed iframe with its own CSP.	ASVS V3, V50
API	Scoped API keys (hash stored, prefix indexed), IP and sender-domain restrictions, expiry and rotation; idempotency keys; body size limits; per-key rate limits.	OWASP API2/API4
SSRF	Webhook, MTA-STS and port-check requests resolve DNS at connect time and refuse loopback, private, link-local, CGNAT and other reserved ranges; no redirects.	OWASP API7
Email	No open relay; DKIM on all outbound mail; SPF/DMARC guidance per domain; suppression of bounces and complaints; RFC 8058 one-click unsubscribe; per-mailbox webmail send limit.	M3AAWG practices
Payments	Webhook HMAC-SHA256 verification over the raw body; idempotent application; final states immutable; amounts in whole KES; audit trail.	PCI-style hygiene (no card data)
Infrastructure	Only required ports public; containers without new privileges or extra capabilities; secrets outside source and web root; security.txt (RFC 9116).	CIS benchmarks
Logging	Audit log of actor, action, target and IP; passwords, tokens and message content never logged; request IDs correlate web and API logs.	ASVS V16

7.2 Secrets and key management

Secret	Protects	Storage and rotation
`DATA_ENCRYPTION_KEY`	DKIM private keys and webhook signing secrets (AES-256-GCM).	`stack.env`; offline copy; rotation requires re-encryption.
Database passwords	Owner, runtime (`mv_app`) and read-only mail-server roles.	`stack.env`; rotate per role.
`INTERNAL_API_TOKEN`	Bounce ingestion from Postfix to the API.	`stack.env` and a root-only file in the Postfix container.
Relay, IMAP master, doveadm keys	API access to Postfix relay, webmail IMAP and access revocation.	`stack.env`; private network only.

Secret	Protects	Storage and rotation
PesaTide, Africa's Talking, Google	Payments, SMS, sign-in.	`stack.env`; rotate in each provider's dashboard.
Backup passphrase	Encrypted backup archives.	Root-only file (chmod 600) and an offline copy.
Session link keys	Sealed links for one browser session.	Random 32 bytes in the session; discarded at sign-out.

7.3 Threats and mitigations

Threat	Mitigation	Residual risk
Credential stuffing and brute force	Rate limits at Nginx and per account; lockouts; breached-password screening; MFA; security alert emails on password and MFA changes.	Low
Cross-tenant data access (IDOR)	Tenant derived from the session; scoped queries; composite foreign keys; sealed links; integration tests per resource.	Low
Cross-site scripting	Escaping by default; strict CSP without inline script; mail bodies sanitised and sandboxed; Markdown renderer escapes all text.	Low
Cross-site request forgery	Synchronizer tokens; SameSite cookies; API double-submit check.	Low
Server-side request forgery	Guarded resolver refusing private and reserved addresses at connect time; no redirects; strict tool inputs.	Low
Open relay or spam abuse by a customer	Relay restrictions; plan quotas; suppressions; per-mailbox send limits; operator suspension with immediate revocation.	Medium: add new-sender limits before open launch
Forged payment confirmation	HMAC-verified webhooks; reconciliation with PesaTide's API; idempotent, immutable final states.	Low
Stolen API key	Hash-only storage; IP and sender-domain restrictions; expiry; one-click revoke and rotate; audit log.	Low–medium
Server compromise	Minimal ports; container hardening; secrets outside the web root; encrypted off-site backups; SSH keys only.	Medium: single VPS
Data loss	Daily encrypted backups with checksums; off-site copy; quarterly restore drill.	Low once the drill is practised

> **Before public launch:** deploy to a staging VPS and prove deliverability to Gmail and Outlook; run one live KES 1 M-Pesa payment and one live SMS code; test the phone setup on real Android and iOS devices; add limits for new senders; commission an independent penetration test; register with Kenya's Office of the Data Protection Commissioner.

8 Data protection

Data	Where it lives	Retention and protection
Accounts	Usernames, names, email, phone, password hashes, MFA secrets (PostgreSQL).	Until the account is deleted; passwords as Argon2id hashes.
Hosted mail	Maildir files in the `vmail` volume.	Controlled by the institution; per-mailbox quotas; encrypted in backups.
Sent-message content	Message bodies in PostgreSQL for delivery and display.	Purged after `CONTENT_RETENTION_DAYS` (30 by default); metadata kept for the delivery log.
Billing	Invoices, payments, M-Pesa receipts and phone numbers.	Kept for statutory accounting periods; no card data processed.
Security events	Audit log: actor, action, target, IP, metadata.	Never contains passwords, tokens or message content.
Phone setup analytics	Setup steps, app chosen, help topics viewed.	No message content; used to improve onboarding.

Kenya Data Protection Act, 2019

- The privacy notice lists every processor (PesaTide, Africa's Talking, Google sign-in, Pwned Passwords) and the right to complain to the Office of the Data Protection Commissioner (ODPC).
- Institutions are data controllers for their staff's mail; Mailvora acts as their processor. The operator should register with the ODPC before launch.
- Data subject requests (access, correction, deletion) are handled by operators from the operator console and the database, and recorded in the audit log.

Backups

`backend/infra/scripts/backup.sh` runs daily from cron. It dumps the database (`pg_dump -Fc`), archives the mailboxes and the configuration, writes SHA-256 checksums, encrypts everything into one archive with GnuPG (AES-256, passphrase file chmod 600), prunes archives older than the retention period, and is copied off the server to a different provider. A restore is drilled on a scratch VPS every quarter.

9 Operations

Monitoring

- `/healthz` on the web app reports web and API health.
- API metrics: outbox depth and oldest pending age, messages and webhook deliveries per hour, suspended organisations, database pool usage.
- Operator console: delivery queue and failed jobs, receivables, security overview (failed sign-ins, locked accounts, operators and owners without MFA, privileged activity).
- Container health checks and automatic restarts; bounded JSON logs.

Incident response

- **Compromised tenant:** suspend the organisation (revokes sessions, keys and mail access immediately), review the audit log, notify the owner.
- **Spam outbreak:** suspend the sender, inspect the queue, requeue or drop jobs, check blocklists with the deliverability tools.
- **Payment dispute:** reconcile with PesaTide by reference and receipt; operators can record or void invoices.
- **Host compromise:** rebuild from a clean image, restore the latest verified backup, rotate every secret in `stack.env`.

Release gates

Gate	Requirement
Automated tests	Rust format, clippy (deny warnings) and test suites; PHP unit and feature tests; real-browser journey; API smoke and mailbox end-to-end scripts.
Mail tier	No open relay from an external host; unknown recipients rejected in SMTP; DKIM verified by an independent implementation.
Configuration	Production start-up validation passes; secrets set; certificates valid for the exact host names.
Security	Operators enrolled in MFA; penetration-test findings rated critical or high resolved.
Recovery	Backup job running; latest archive restored successfully on a scratch host.

A Network and port reference

Port	Service	Purpose	Reachable from
22	SSH	Administration (keys only, no root login)	Operator IPs
25	Postfix	Inbound MX; outbound delivery to other servers	Internet
80	Nginx	Redirect to HTTPS; ACME challenges	Internet
443	Nginx	Web app, API, autoconfig/Autodiscover over TLS	Internet
465	Postfix	Client submission, implicit TLS (RFC 8314)	Internet
587	Postfix	Client submission, STARTTLS	Internet
993	Dovecot	IMAP over TLS	Internet
8080	Web app	Apache + PHP (behind Nginx)	Loopback only
8088	API	Rust REST API (behind Nginx and the web app)	Loopback only
5432	PostgreSQL	Database	Private network
10587	Postfix	Platform relay for API mail (SASL)	Private network
10026	Postfix	Auto-reply injection from Dovecot	Private network
11332	Rspamd	Milter	Private network
6379	Redis	Rspamd state	Private network
24	Dovecot	LMTP delivery from Postfix	Private network
12345	Dovecot	SASL authentication for Postfix	Private network
8080	Dovecot	doveadm HTTP API (access revocation)	Private network
4190	Dovecot	ManageSieve (vacation replies, filters)	Private network
10993	Dovecot	Quota policy service for Postfix	Private network

Host names

Host	Serves
`app.example.com`	Website, console, operator console, webmail, phone setup, documentation
`api.example.com`	REST API for applications (internal and webmail paths blocked)
`mail.example.com`	MX target and IMAP/SMTP host (A and PTR records)
`autoconfig.example.com`	Thunderbird autoconfig and Outlook Autodiscover

B Document control

Item	Value
Document	Mailvora System Infrastructure
Version	1.0 (pre-production baseline)
Date	15 October 2026
Owner	Platform operations, Mailvora
Classification	Confidential: platform operators and authorised reviewers
Review cycle	Every release that changes topology, ports or security controls, and at least every six months
Source	`frontend/resources/infrastructure/system-infrastructure.html`, built with `frontend/scripts/build_infrastructure_pdf.py`
Related	Operator wiki: Architecture, Security model, Security readiness, Sealed links, Operations, VPS deployment, Configuration

Revision history

Version	Date	Changes
1.0	15 Oct 2026	First edition: context, deployment, flows, security architecture, controls, data protection, operations, port reference.

© 2026 Mailvora. All rights reserved. Powered by **TECHCORE SOLUTIONS**.